

WU - CTI HackHer 2026

La catégorie CTI du HackHer CTF 2026 s'articule autour de quatre challenges principaux. Ce write-up présente, pour chacun d'eux, une méthodologie détaillée permettant d'aboutir à leur résolution.

Challenge 1 : Un monde très dystopique	2
Challenge 2 : Orwellien	3
Challenge 3 : L'algo de minecraft	5
Challenge 4 : Big brother is watching the snow	7
Un peu de lecture pour mieux comprendre certaines choses...	8



WU - CTI HackHer 2026

Challenge 1 : Un monde très dystopique

Courant février 2022...

La porte de votre bureau s'ouvre brusquement. Votre directrice technique, habituellement imperturbable, est en nage. Elle ferme la porte derrière elle et baisse la voix.

« Écoute, j'ai eu vent d'une rumeur terrifiante en réunion comex. Il paraît qu'une backdoor Linux traîne sur les réseaux mondiaux depuis plus de 10 ans. Invisible. Intouchable. On parle de niveau étatique, le genre de truc capable de passer au travers de tous nos pare-feux sans déclencher une seule alerte. »

Elle marque une pause, regardant nerveusement le serveur dans le coin de la pièce.

« Si nos systèmes sont compromis depuis tout ce temps... on est morts. Je veux que tu creuses. Trouve-moi tout sur cette histoire : le nom de l'opération, comment ça marche, qui est derrière et surtout, comment on détecte cette saloperie. Je veux des faits, pas des rumeurs. »

Votre mission commence maintenant.

Flag : HackHer{1984}

Ce premier challenge sert surtout d'introduction pour donner du contexte aux joueuses avant la suite.

Flag : HackHer{1984}

WU - CTI HackHer 2026

Challenge 2 : Orwellien

Une backdoor Linux active pendant 10 ans, attribuée à Equation Group, a été exposée publiquement en février 2022. Le rapport d'analyse lie cette campagne à une référence du roman 1984.

Quel est le nom de l'opération ?

Format : HackHer{nom_operation}

Méthodologie :

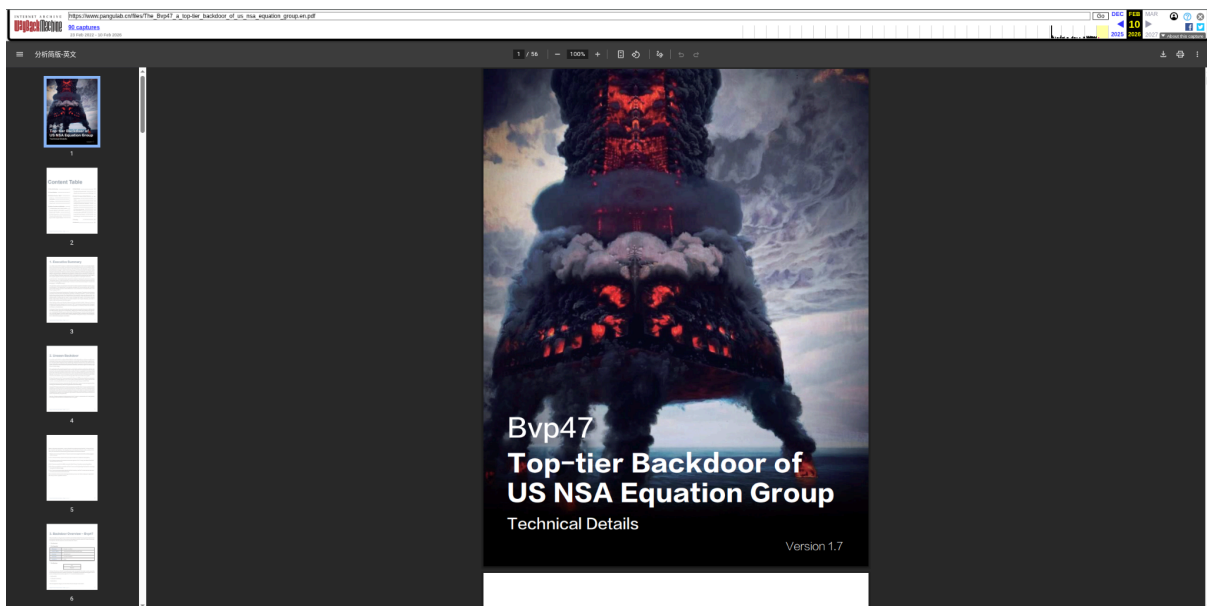
The screenshot shows a Google search interface with the query "equation group" "1984". The search results are displayed in a dark theme. The first result is from Guardia Cybersecurity School, titled "Les principaux groupe de cybercriminels ou groupe d' ...", dated 9 janv. 2025, mentioning Equation Group and Shadow Brokers. Below this is a section titled "Autres questions" with four related questions: "Quel est le groupe de hackers le plus célèbre au monde ?", "Qui sont les hackers les plus connus ?", "Quel est le classement des pays les plus ciblés par les hackers ?", and "Qui est un hacker éthique connu ?". The second search result is from 盘古实验室 (Pangulab), titled "Bvp47 – Top-tier Backdoor of US NSA Equation Group", dated 56 pages, mentioning that Equation Group belongs to NSA and that Bvp47 is a top-tier backdoor. The third result is from Cairn.info, titled "Chapitre 9. L'adaptation du renseignement à la ...", mentioning Equation Group and the NSDD 145 directive. The fourth result is from OpenEdition Journals, titled "Cyberguerre et géographie", mentioning a theorem by Fred Cohen from 1984. The fifth result is from Wikipédia, titled "Cisco Systems", dated 10 décembre 1984, mentioning Sandra Lerner, Leonard Bosack, and the company's founding.

WU - CTI HackHer 2026

En premier lieu, j'ai procédé à une recherche par Google Dorking avec les termes « equation group » et « 1984 ». Cependant, lorsque l'on clique sur le premier lien (https://www.pangulab.cn/files/The_Bvp47_a_top-tier_backdoor_of_us_nsa_equation_group.en.pdf), celui-ci ne fonctionne pas.

Deux choix s'offraient alors à moi : passer au résultat suivant, ou tenter d'y accéder d'une autre manière. Évidemment, j'ai choisi la deuxième solution. L'une des possibilités est de vérifier s'il existe des archives de cette page web. Pour cela, quoi de mieux que la Wayback Machine ?

https://web.archive.org/web/20260210141450/https://www.pangulab.cn/files/The_Bvp47_a_top-tier_backdoor_of_us_nsa_equation_group.en.pdf



Si nous prenons la dernière archive nous avons bien accès au rapport !!
Et dans l'exécutive summary nous pouvons retrouver le nom de l'opération.

Pangu Lab has a code named "Operation Telescreen" for several Bvp47 incidents. Telescreen is a device imagined by British writer George Orwell in his novel "1984". It can be used to remotely monitor the person or organization deploying the telescreen, and the "thought police" can arbitrarily monitor the information and behavior of any telescreen.

Flag : HackHer{operation_telescreen}

Challenge 3 : L'algo de minecraft

L'analyse binaire de la backdoor montre que l'échange de clés est asymétrique (RSA). Cependant, le canal de commande (C2) est chiffré via un algorithme symétrique spécifique (non-AES).

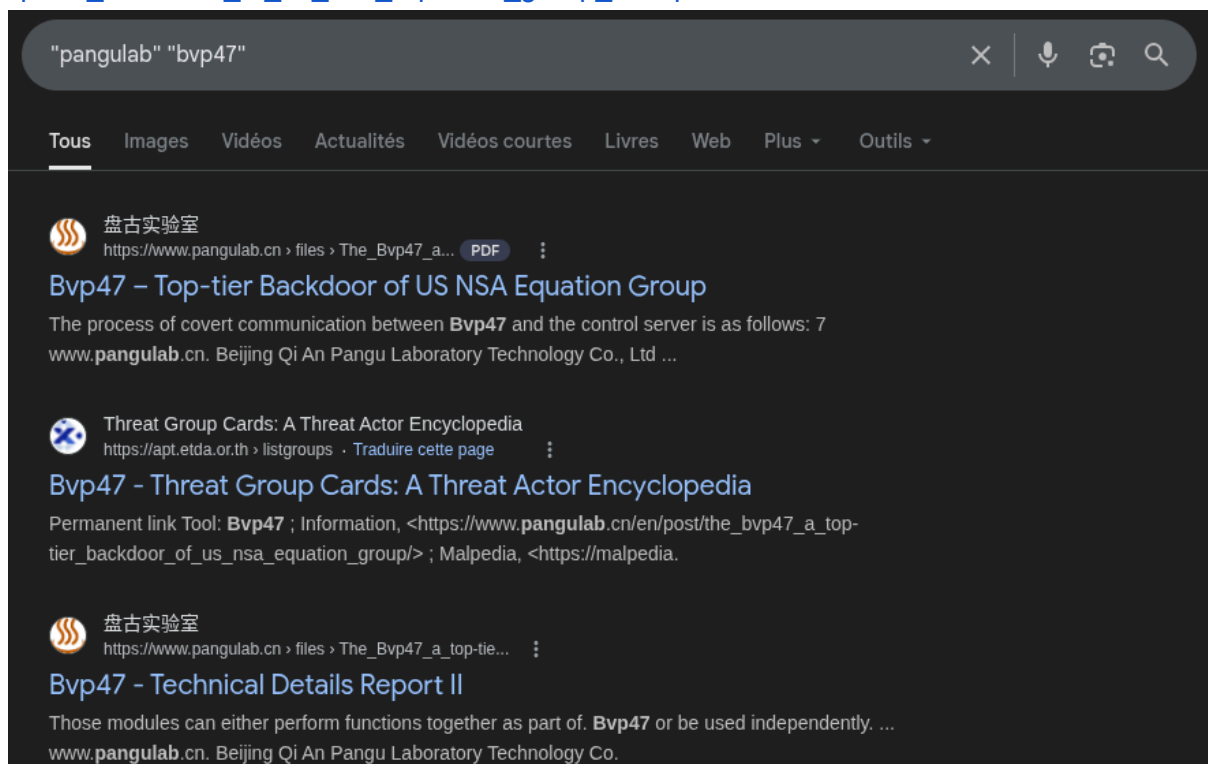
Lequel ?

Trois essais maximum

Format : HackHer{XXX}

Nous savons que PanguLab est à l'origine de la découverte de cette opération, mais le précédent rapport ne parle pas d'algorithme de chiffrement de C2. Cherchons de nouvelles infos...

https://web.archive.org/web/20251207154033/https://www.pangulab.cn/files/The_Bvp47_a_top-tier_backdoor_of_us_nsa_equation_group_ii.en.pdf



Nous voici donc avec un nouveau rapport, mais le problème se répète : il est impossible de l'ouvrir. Nous pouvons par conséquent tenter la même approche avec la Wayback Machine que celle vue précédemment. En prenant le temps de le lire avec passion (parce qu'on adore la CTI !), on peut y relever un passage particulièrement intéressant.

● Private Key of suctionchar_decode

As described in the scene, the file `"/var/tmp/.e33ff11cb8e3b4ff/a0b973925e397d9acd80e85e2eaa6e60/d5373a146ff9f200a2376054dde25677"` can be decrypted by the `"linux/bin\suctionchar_decode"` program, and the encryption algorithm needs to use the RSA private key to decrypt the RC6 symmetric key file. Like the private key in Dewdrops, this RSA private key can also support the association between the backdoor and The Shadow Brokers leaked data package.

WU - CTI HackHer 2026

Flag : HackHer{RC6}

Challenge 4 : Big brother is watching the snow

Il nous manque une information cruciale.
Qui est derrière cette backdoor..

Quelle affaire a permis de démasquer l'auteur de cette backdoor ?
Quel bout de code a été la clé de cette identification ?
Qui a publié des fichiers contenant ce code, qui a permis de lier BVP47 à cette affaire ?
Et surtout, qui tire les ficelles derrière tout ça ?

Format : HackHer{affaire_identification_code_auteur}

Si vous avez fait attention jusqu'ici, un élément aurait dû vous interloquer.

● Private Key of suctionchar_decode

As described in the scene, the file `"/var/tmp/.e33ff11cb8e3b4ff/a0b973925e397d9acd80e85e2aaa6e60/d5373a146ff9f200a2376054dde25677"` can be decrypted by the `"linux/bin\suctionchar_decode"` program, and the encryption algorithm needs to use the RSA private key to decrypt the RC6 symmetric key. file. Like the private key in Dewdrops, this RSA private key can also support the association between the backdoor and The Shadow Brokers leaked data package.

Intéressant, si nous reprenons le premier PDF de pangulab. Nous pouvons retrouver une partie "Connection with Snowden Incident".

■ Connection with Snowden Incident

In December 2013, the German media "Der Spiegel" published an NSA ANT catalog with 50 pictures. This is a series of top-secret materials compiled by the NSA in 2008-2009, including the use of a series of advanced hacking tools. The source of information may come from Edward Snowden or another unknown intelligence provider [Reference 3].

The FOXACID-Server-SOP-Redacted.pdf file in the NSA ANT catalog [Reference 4], that is, the "Acid Fox" Project-Server Standard Operating Procedure Revision, NSA Vulnerability Attack Operating Platform Functional Description and User Manual, in this standard work. The document describes the mandatory unique identification code required for the job, "ace02468bdf13579".

Nous savons donc que l'événement qui a permis d'identifier l'auteur de cette backdoor est l'affaire Snowden. Nous connaissons également le fragment de code en question (ace02468bdf13579), et nous savons que ce sont les Shadow Brokers qui ont fait fuiter (ou leaké) les informations le contenant.

Il nous manque cependant une pièce maîtresse au puzzle : qui est suffisamment puissant pour orchestrer une telle opération tout en restant dans l'ombre ?

Nous trouvons la réponse un peu plus bas !

Therefore, there are enough reasons to believe that the two compressed files leaked by Shadow Brokers in 2016 and 2017 belonged to the NSA Equation group's hacking tools.

WU - CTI HackHer 2026

Flag : HackHer{snowden_shadowbrokers_ace02468bdf13579_nsa}

WU - CTI HackHer 2026

Un peu de lecture pour mieux comprendre certaines choses...

https://web.archive.org/web/20260210141450/https://www.pangulab.cn/files/The_Bvp47_a_t_op-tier_backdoor_of_us_nsa_equation_group.en.pdf

https://web.archive.org/web/20251207154033/https://www.pangulab.cn/files/The_Bvp47_a_t_op-tier_backdoor_of_us_nsa_equation_group_ii.en.pdf

https://grokipedia.com/page/Equation_Group

Et le plus cool de tous :

<https://www.diploweb.com/L-attribution-publique-des-cyberattaques-comme-strategie-diplomatique-defensive.html>